PBL KEAMANAN SIBER

SOC Simulation



Kelompok 6 Kelas B

- Razan Fajar Raspati (J0404241175)
- Mirza Zahran Rafif Yanuardi (J0404241085)
- Duta Adithya Dewa (J0404241115)
- Kevin Dwira Al Fathan (J0404241164)

KONTEKS PROYEK IOT: SMILE

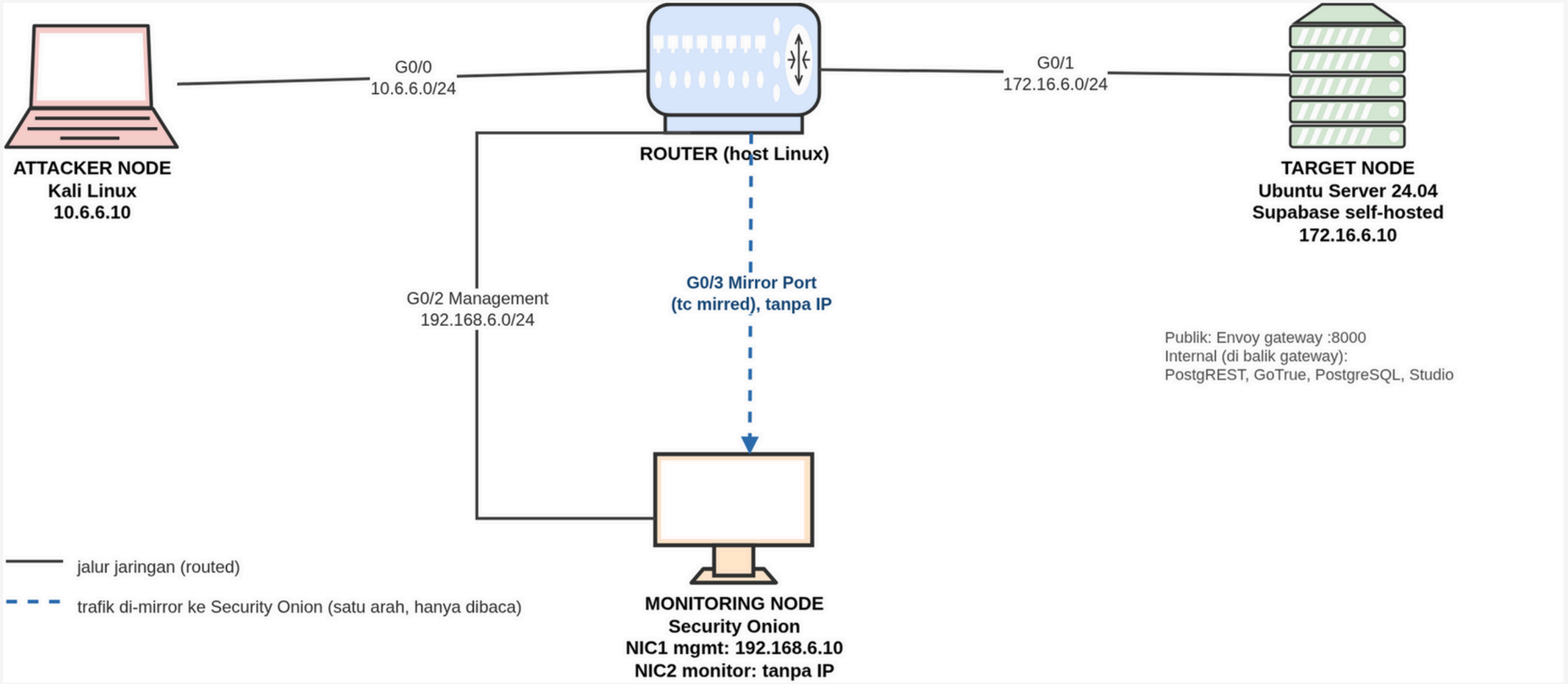
- SMILE (Smart Soil Monitoring System) adalah sistem berbasis IoT untuk mendukung budidaya kopi dengan memantau kondisi tanah secara otomatis dan real-time, lalu mengolah datanya untuk membantu petani mengambil keputusan irigasi dan pemupukan.
- Tujuannya adalah meningkatkan efektivitas pemantauan, efisiensi irigasi, dan ketepatan pemupukan tanaman kopi lewat penerapan precision agriculture.



DEKLARASI TECH STACK & REPLIKASI

KOMPONEN	PROYEK IOT ASLI	TARGET NODE REPLIKA
Sistem Operasi Backend	Managed oleh Supabase Cloud	Ubuntu Server 24.04 LTS (VM lab)
Database	PostgreSQL (Supabase Cloud)	PostgreSQL 15 (container, self-hosted Supabase)
Layar Autentikasi	Supabase Auth (GoTrue, JWT)	GoTrue (container)
Protokol Komunikasi Sensor	HTTP REST via PostgREST (ESP32 → endpoint REST)	PostgREST (container) di balik Kong API Gateway
API Gateway	Kong (Supabase Cloud)	Kong (container)
Dashboard / Monitoring	Aplikasi mobile Flutter (client-side)	Supabase Studio (dashboard web bawaan) sebagai stand-in backend yang dapat diuji Red Team

ARSITEKTUR SIMULASI



PROGRESS HARDENING & BASELINE

No	Kategori	Kontrol	Target Layanan/ File	Status
A1	**Access & Authentication**	Nonaktifkan login root langsung via SSH (PermitRootLogin no)	OS (Ubuntu VM)	Done
A2	**Access & Authentication**	SSH key-based auth, disable password auth (PasswordAuthentication no)	OS (Ubuntu VM)	Done
A3	**Access & Authentication**	fail2ban untuk rate-limit percobaan login SSH & Auth	OS + GoTrue	Done
A4	**Access & Authentication**	Ganti kredensial default Supabase Studio & dashboard (bukan admin/admin bawaan)	Supabase Studio	Done

No	Kategori	Kontrol	Target Layanan/ File	Status
B1	**Service & Attack Surface**	Firewall (ufw) whitelist — hanya izinkan port Kong gateway (8000/8443) + SSH; tutup 5432, 3000, 9999 dari akses eksternal	OS / semua service	Done
B2	**Service & Attack Surface**	Pastikan PostgreSQL (5432) tidak bind ke 0.0.0.0 — hanya internal Docker network	PostgreSQL	Done
B3	**Service & Attack Surface**	Update & patch image Docker Supabase + paket OS ke versi aman terbaru	OS + containers	Sebagian
B4	**Service & Attack Surface**	Nonaktifkan service/endpoint yang tidak dipakai (mis. Realtime/Storage bila tak dipakai)	Docker Compose	Done

PROGRESS HARDENING & BASELINE

No	Kategori	Kontrol	Target Layanan/File	Status
C1	**Data & Application**	Aktifkan & perketat Row Level Security (RLS) pada tabel data sensor + user (default PostgREST expose semua tanpa RLS)	PostgreSQL / PostgREST	Done
C2	**Data & Application**	Kredensial tidak hardcoded — pindahkan JWT secret, DB password, API keys ke env var/secrets (rotasi dari default)	Semua service (.env)	Sebagian
C3	**Data & Application**	Least-privilege pada user DB — buat role khusus untuk PostgREST (bukan superuser postgres)	PostgreSQL	Sebagian
C4	**Data & Application**	Logging aktivitas mencurigakan diaktifkan (Postgres log + Kong access log) diteruskan agar terbaca Security Onion	Postgres + Kong	Sebagian

SKENARIO ATTACK PLAN

S1

- Kategori: Reconnaissance
- Tools Wajib: nmap
- Target Spesifik: 172.16.6.10 (fokus Port 22 & 8000; cek kebocoran 3000, 9999, 5432)
- Korelasi Celah / Tech Stack: Pengujian attack surface untuk mengevaluasi apakah host firewall (UFW) dan desain gateway Envoy berhasil menyembunyikan layanan internal (PostgREST 3000, GoTrue 9999, PostgreSQL 5432) dari pemindaian eksternal, sehingga di jaringan lab 172.16.6.0/24 hanya SSH (22) dan Envoy gateway (8000) yang terekspos.

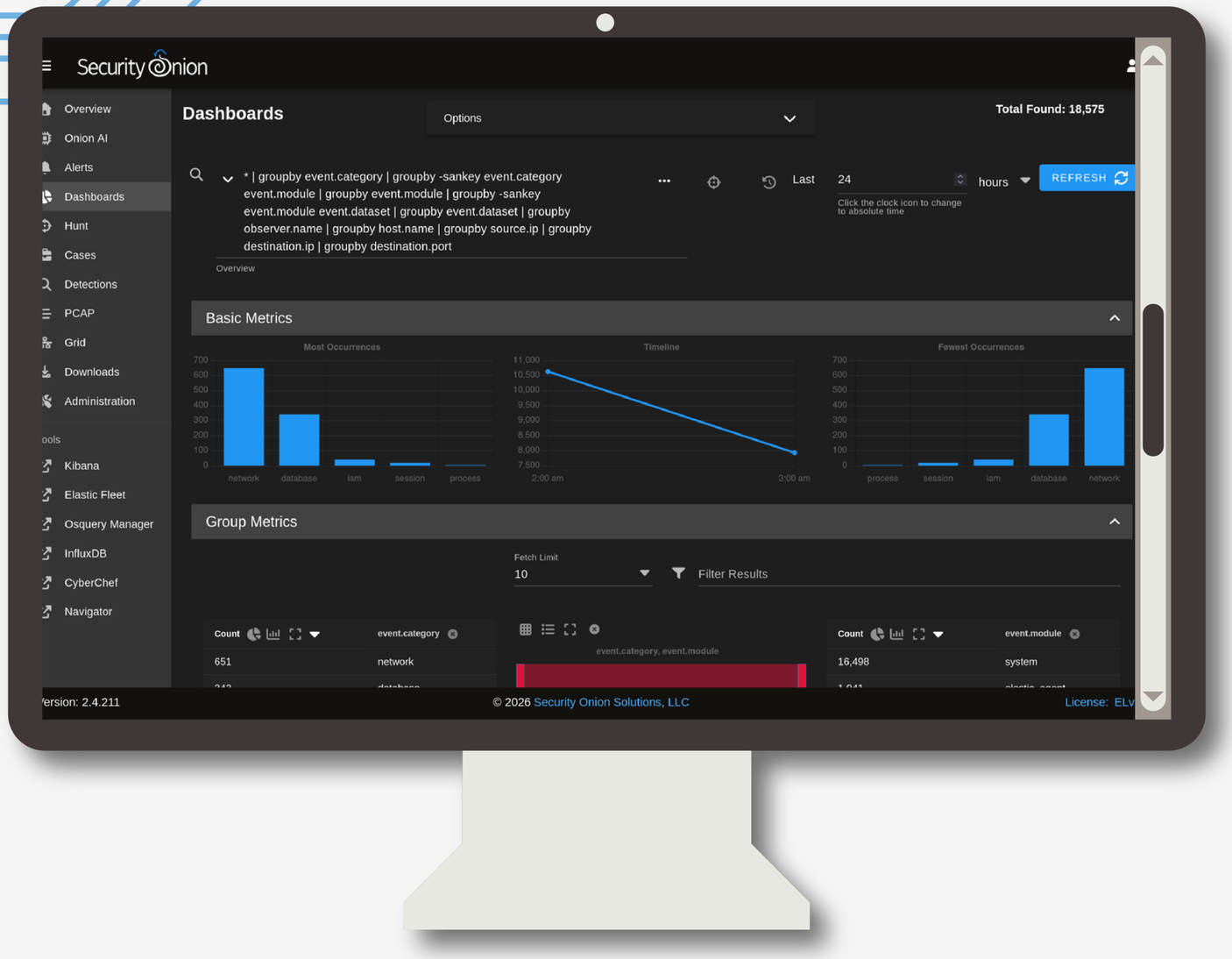
S2

- Kategori: Web / API / Protokol IoT
- Tools Wajib: Burp Suite
- Target Spesifik: Endpoint PostgREST via Envoy http://172.16.6.10:8000/rest/v1/sensor_readings
- Korelasi Celah / Tech Stack: Pengujian kerahasiaan data sensor IoT (Broken Access Control). Di balik Envoy gateway, PostgREST otomatis mengekspos ttabel sensor_readings dan profiles tanpa Row Level Security (RLS) aktif, pemegang anon key dapat membaca seluruh isi tabel tanpa otorisasi yang benar.

S3

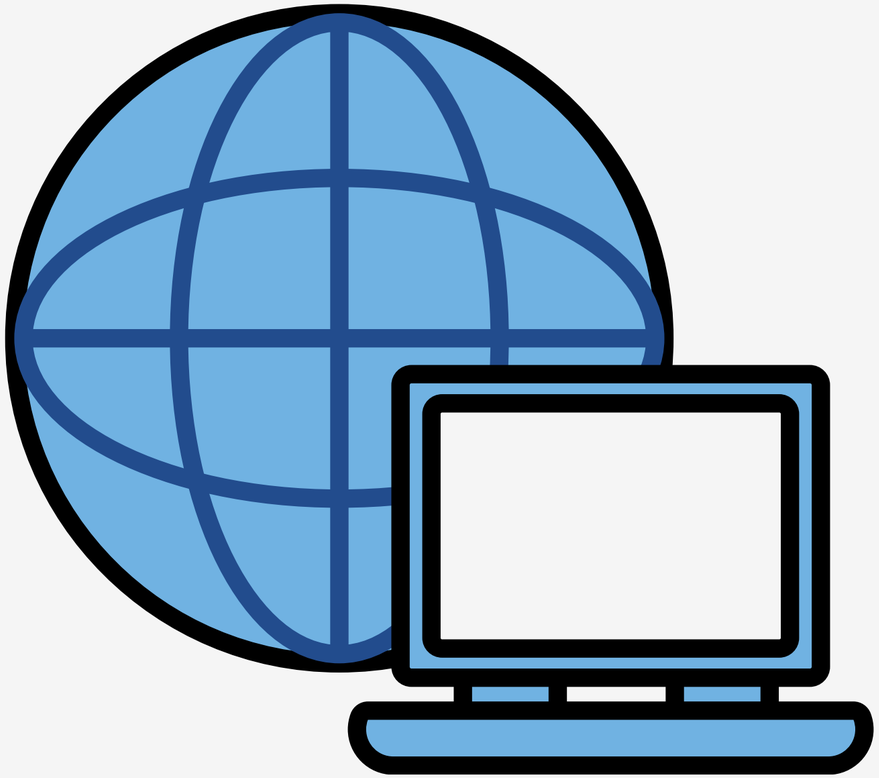
- Kategori: Exploitation / Akses
- Tools Wajib: Hydra
- Target Spesifik: Endpoint autentikasi via Envoy http://172.16.6.10:8000/auth/v1/token & login Supabase Studio
- Korelasi Celah / Tech Stack: Pengujian ketahanan mekanisme autentikasi terhadap serangan tebakan kredensial berulang (dictionary attack), serta validasi keaktifan rate-limit. Kredensial dashboard bawaan (DASHBOARD_USERNAME/PASSWORD) yang belum diganti menjadi sasaran utama.





SECURITY ONION MONITORING DEMO

KENDALA & PEMBELAJARAN



Kendala

- Security Onion dan Supabase self-hosted berjalan bersamaan sehingga VM berat di RAM terbatas
- Mirror traffic (SPAN) ke Monitoring Node tidak langsung terbaca di Security Onion
- Sinkronisasi jadwal kerja Red Team dan Blue Team sulit diatur

Pembelajaran

- Mengatur ulang alokasi RAM tiap VM dan mematikan layanan yang tidak dipakai agar lab tetap stabil
- Memperbaiki konfigurasi NIC sniffing dan tc mirred sehingga traffic terbaca di Security Onion
- Menyepakati pembagian tugas dan jadwal bersama

Terima Kasih